

RELATÓRIO TÉCNICO: AUDITORIA DE SEGURANÇA E TESTES DE FORÇA BRUTA

1. Introdução

Este documento apresenta o detalhamento técnico do laboratório de segurança ofensiva realizado para simulação de ataques de força bruta e auditoria de credenciais. O projeto foca na utilização de ferramentas padrão da indústria para identificar fragilidades em serviços de rede e aplicações web, visando a proposição de medidas defensivas robustas.

2. Escopo e Objetivos

- Configuração de ambiente controlado para testes de penetração.
- Execução de varredura de serviços e reconhecimento de rede.
- Simulação de ataques de dicionário e força bruta paralela.
- Documentação de vetores de ataque e estratégias de mitigação.

3. Ambiente Tecnológico

O laboratório foi estruturado em um ambiente de virtualização isolado para garantir a segurança da rede externa e a integridade dos testes.

Componente	Descrição
Virtualizador	Oracle VM VirtualBox
Rede	Host-only (Exclusiva de Hospedeiro)

Componente	Descrição
Máquina Atacante	Kali Linux
Máquina Alvo	Metasploitable 2
IP Alvo	192.168.56.101

4. Metodologia de Execução

4.1. Reconhecimento (Footprinting)

Foi realizada uma varredura de portas para identificar serviços vulneráveis no alvo utilizando o Nmap.

```
nmap -sV -p 21,22,80,445,139 192.168.56.101
```

O resultado indicou a presença do serviço **vsftpd 2.3.4** na porta 21 e o servidor **Apache** na porta 80.

4.2. Preparação de Wordlists

Dicionários customizados foram gerados para simular tentativas de login com usuários e senhas comuns:

- **Usuários:** user, msfadmin, admin, root.
- **Senhas:** 123456, password, qwerty, msfadmin.

4.3. Ataque de Força Bruta (FTP)

Utilizou-se o **Medusa** para testar as combinações no serviço FTP de forma paralela:

```
medusa -h 192.168.56.101 -U User.txt -P Pass.txt -M ftp -t 6
```

Resultado: Credenciais **msfadmin:msfadmin** identificadas com sucesso.

4.4. Ataque a Formulário Web (HTTP Form)

O teste foi estendido para o formulário de login da aplicação DVWA:

```
medusa -h 192.168.56.101 -U User.txt -P Pass.txt -M http -m PAGE:'/dvwa/login.php' -m FO
```

Resultado: Identificação de usuários e senhas válidos para acesso administrativo à aplicação.

5. Análise de Resultados e Mitigação

Ameaça	Medida de Prevenção
Credenciais Padrão	Impor a troca de senhas de fábrica no primeiro acesso.
Força Bruta / Dicionário	Implementar Account Lockout (Bloqueio de conta após erros).
Tráfego em Texto Claro	Substituir FTP por SFTP (SSH File Transfer Protocol).
Ataques Automatizados	Implementar CAPTCHA e ferramentas como Fail2Ban ou WAF.

6. Conclusão

O laboratório demonstrou que a ausência de políticas básicas de segurança, como o uso de credenciais padrão e a falta de mecanismos de bloqueio de tentativas sucessivas, torna a infraestrutura extremamente vulnerável. A implementação das medidas defensivas propostas é crítica para a manutenção da tríade da segurança.

Responsável Técnico: Luan Francisco Savarese

Data: 06 de maio de 2026